



Actividad 01 · Análisis y planificación del pentest

Elaborado por Ada J. Vargas A.

1. Objetivo del pentest

Los principales objetivos de la evaluación de seguridad de Aurora Market son:

- i. Identificar los riesgos
- ii. Evaluar el posible impacto de dichos riesgos
- iii. Proponer medidas para fortalecer la seguridad y reducir riesgos

La finalidad es responder a la pregunta “¿qué podría descubrir un atacante con base en la información disponible?”

2. Alcance

Los sistemas y elementos incluidos dentro de la evaluación incluyen:

- La aplicación web
- Mecanismo de autenticación ligado a la web app
- Base de datos ligada a la web app

Aclaración: Tanto el mecanismo de autenticación como la base de datos ligados a la aplicación son componentes de esta, se requieren para el correcto funcionamiento de la misma.

Mientras que los elementos fuera del alcance son:

- Redes sociales
- Correos
- Equipos
- Proveedores
- Otros sistemas

3. Autorización y Condiciones

A continuación, se describen los permisos requeridos:

- Permisos para identificar vulnerabilidades de la aplicación web, incluyendo las conexiones a mecanismos de autenticación y bases de datos (ej.: formularios).

Asimismo, las condiciones acordadas previo a las pruebas son:

- No realizar acciones que interrumpan la operación de la plataforma.
- No realizar acciones que afecten datos reales.



- Cualquier problema detectado deberá ser documentado detalladamente.
- Designar a un punto de contacto de Aurora Market.

4. Tipo de pentest

Se ha seleccionado un pentest tipo black-box. La justificación de esta elección radica en que el equipo de Aurora Market no ha provisto toda la información técnica de su sitio, ni ha brindado credenciales o diagramas de arquitectura; por ende, se tiene información limitada, justo como un atacante externo.

5. Planificación

- **Objetivos**
Dialogar con el equipo de Aurora Market para conocer cuál es el producto final que espera de la evaluación de su aplicación. Acto seguido, definir los objetivos y realizar los ajustes necesarios con el cliente para que quede claramente definido qué es lo que se espera/busca con el pentest.
- **Alcance**
Delimitar qué sí y que no se evaluará en la prueba de penetración.
Una vez definido el alcance, este deberá ser confirmado por el cliente.
- **Permisos y Condiciones**
Obtener los permisos necesarios para llevar a cabo las pruebas (indicando para qué se requiere cada uno), y establecer por escrito las condiciones del pentest.
- **Metodología**
Una vez establecido el tipo de pentest, se deberá seleccionar un marco de referencia o guía estándar para definir el “cómo”.
- **Recopilación de Información Previa**
Reunir toda la información pública sobre la aplicación, incluyendo, pero limitado a: dominio, subdominios, tecnologías empleadas.
- **Recursos Necesarios**
Definir la cantidad de personas para la prueba, así como sus perfiles.



Establecer cuáles serán las herramientas para usar, como entornos de pruebas, softwares, etc.

- Programación del Pentest
Estimar el tiempo para cada fase: reconocimiento, análisis, explotación, informe.

6. Fases del pentest

- Reconocimiento**
Recopilar información pública: investigación en motores de búsqueda, subdominios asociados, configuración de DNS, información expuesta del código fuente del lado del usuario (HTML / JS), metadatos públicos (encabezados, certificados SSL).
- Análisis de Vulnerabilidades**
Buscar, documentar y analizar vulnerabilidades, teniendo presente el OWASP 10:
 - Inyección
 - Autenticación interrumpida
 - Exposición de datos confidenciales
 - Entidades externas XML (XXE)
 - Control de acceso roto
 - Configuraciones incorrectas de seguridad
 - Scripting entre sitios (XSS)
 - Deserialización segura
 - Registro y monitoreo insuficientes
- Explotación**
Se proponen los siguientes métodos:
 - Inyección: Donde se pruebe una consulta simple para confirmar el acceso, sin extraer datos de clientes.
 - Autenticación interrumpida: Probar ataques de fuerza bruta controlados en cuentas de prueba, no de clientes reales
 - XSS: Inyectar un script de prueba inofensivo para confirmar su ejecución
- Post-Explotación**
Con base en los métodos descritos anteriormente, lo que se evaluaría como impacto es lo siguiente:



- ¿Qué tanto de la base de datos queda expuesto?
- Si una cuenta está comprometida, ¿a qué información y/o funciones se puede acceder?
- Evaluar si el script tendría la capacidad de usarse para robar sesiones de usuarios reales.

v. Informe

Redactar el informe ejecutivo para resumir los hallazgos, indicar el impacto comercial y las recomendaciones; en este caso, el público objetivo son los ejecutivos de la empresa.

Asimismo, escribir el informe técnico orientado al equipo de TI de Aurora Market para describir las vulnerabilidades, documentar las pruebas realizadas con su evidencia, describir el impacto técnico y plasmar las recomendaciones con detalle.

7. Investigación

Ahora bien, la metodología elegida es **OWASP**, considerando OWASP Top 10 y el marco de referencia Web Security Testing Guide (WSTG).

Se considera que sería útil para este proyecto porque el primero enlista las vulnerabilidades y riesgos de ciberseguridad actualizados en aplicaciones web; mientras que el segundo recurso permite que se implementen las mejores prácticas, como técnicas y tareas para cada etapa del pentest.